

- Standards for controls;
- Minimum acceptable service provider characteristics;
- Monitoring and reporting;
- Transition requirements;
- Contract duration, termination, and assignment' and
- Contractual protections against liability.

B. DUE DILIGENCE

1. Assess the extent to which the institution reviews the financial stability of the service provider:

- Analyzes the service provider's audited financial statements and annual reports;
- Assesses the provider's length of operation and market share;
- Considers the size of the institution's contract in relation to the size of the company;
- Reviews the service provider's level of technological expenditures to ensure on-going support; and
- Assesses the impact of economic, political, or environmental risk on the service provider's financial stability.

2. Evaluate whether the institution's due diligence considers the following:

- References from current users or user groups about a particular vendor's reputation and performance;
- The service provider's experience and ability in the industry;
- The service provider's experience and ability in dealing with situations similar to the institution's environment and operations;
- The quality and effectiveness of any cost/benefit analyses. Determine whether the analysis considered the incremental costs of the additional monitoring, operations responsibilities, and protections that may be required of the financial institution.
- The cost for additional system and data conversions or interfaces presented by the various vendors;
- Shortcomings in the service provider's expertise that the institution would need to

supplement in order to fully mitigate risks;

- The service provider's proposed use of third parties, subcontractors, or partners to support the outsourced activities;
- The service provider's ability to respond to service disruptions;
- Key service provider personnel that would be assigned to support the institution;
- The service provider's ability to comply with appropriate federal and state laws. In particular, ensure management has assessed the providers' ability to comply with federal laws (including GLBA and the USA PATRIOT Act); and
- Country, state, or locale risk.

C. SERVICE CONTRACT

1. Verify that legal counsel reviewed the contract prior to closing.

- Ensure that the legal counsel is qualified to review the contract particularly if it is based on the laws of a foreign country or other state; and
- Ensure that the legal review includes an assessment of the enforceability of local contract provisions and laws in foreign or out-of-state jurisdictions.

2. Verify that the contract appropriately addresses:

- Scope of services;
- Performance standards;
- Pricing;
- Controls;
- Financial and control reporting;
- Right to audit;
- Ownership of data and programs;
- Confidentiality and security;
- Regulatory compliance;
- Indemnification;
- Limitation of liability;
- Dispute resolution;

- Contract duration;
- Restrictions on, or prior approval for, subcontractors;
- Termination and assignment, including timely return of data in a machine-readable format;
- Insurance coverage;
- Prevailing jurisdiction (where applicable);
- Choice of Law (foreign outsourcing arrangements);
- Regulatory access to data and information necessary for supervision; and
- Business Continuity Planning.

3. Review service level agreements to ensure they are adequate and measurable. Consider whether:

- Significant elements of the service are identified and based on the institution's requirements;
- Objective measurements for each significant element are defined;
- Reporting of measurements is required;
- Measurements specify what constitutes inadequate performance; and
- Inadequate performance is met with appropriate sanctions, such as reduction in contract fees or contract termination.

4. Review the institution's process for verifying billing accuracy and monitoring any contract savings through bundling.

D. MONITORING SERVICE PROVIDER RELATIONSHIP(S)

1. Evaluate the institution's periodic monitoring of the service provider relationship(s), including:

- Timeliness of review, given the risk from the relationship;
- Changes in the risk due to the function outsourced;
- Changing circumstances at the service provider, including financial and control

environment changes;

- Conformance with the contract, including the service level agreement; and
- Audit reports and other required reporting addressing business continuity, security, and other facets of the outsourcing relationship.

2. Review risk rankings of service providers to ascertain:

- Objectivity;
- Consistency; and
- Compliance with policy.

3. Review actions taken by management when rankings change, to ensure policy conformance when rankings reflect increased risk.

4. Review any material subcontractor relationships identified by the service provider or in the outsourcing contracts. Ensure:

- Management has reviewed the control environment of all relevant subcontractors for compliance with the institution's requirements definitions and security guidelines; and
- The institution monitors and documents relevant service provider subcontracting relationships including any changes in the relationships or control concerns.

Appendix B: Laws, Regulations, and Guidance

Laws

- 12 USC 1464 (d) (7): Home Owners' Loan Act (Thrifts) (N/A)
- 12 USC 1867 (c) (11): Bank Service Company Act (Banks) (N/A)
- 15 USC 6801: Gramm-Leach-Bliley Act (N/A)
- Pub. L. No. 107-56: USA PATRIOT Act (N/A)

Federal Reserve Board

- SR 00-4 (SUP): Outsourcing of Information and Transaction Processing (February 2000)
- SR 00-17 (SPE): Guidance on the Risk Management of Outsourced Technology Services (November 30, 2000)

Federal Deposit Insurance Corporation

- FIL-49-99: Bank Service Company Act (June 3, 1999)
- FIL-50-2001: Bank Technology Bulletin: Technology Outsourcing Information Documents (June 4, 2001)

National Credit Union Administration

- NCUA Letter to Credit Unions No. 02-CU-17: E-Commerce Guide for Credit Unions (December 2002)
- NCUA Letter to Credit Unions No. 01-CU-20: Due Diligence Over Third Party Service Providers (November 2001)

Office of the Comptroller of the Currency

- OCC Bulletin 2002-16: Bank Use of Foreign-Based Third-Party Service Providers (May 15, 2002)
- OCC Bulletin 2001-47: Third-Party Relationships, Risk Management Principles (November 1, 2001)

Office of Thrift Supervision

- 12 CFR Part 570, Appendix B: Interagency Guidelines Establishing Standards for Safeguarding Customer Information (N/A)
- CEO Letter 113: Internal Controls (July 14, 1999)
- Thrift Activities Handbook: Section 340: Internal Control (December 2003)
- Thrift Activities Handbook: Section 341: Technology Risk Controls (October 1997)

Appendix C: Foreign-Based Third-Party Service Providers

The material provided in this appendix focuses on foreign-based third-party service providers and should be used, in addition to all other material in this booklet, when examining such relationships. This appendix discusses the primary risks that may arise from service relationships between financial institutions and foreign-based third-parties ^[6], the steps institutions should consider when managing those risks, and the implications of the relationships within the context of the examination process.

BACKGROUND

Organizations often use domestic third-party service providers as an economic alternative to internal technology and data processing functions. Increasingly, these organizations are considering arrangements with foreign-based third parties or domestic firms that subcontract portions of their operations to foreign-based entities.

The use of foreign-based service providers is a common business practice that can be a less costly alternative to self-processing or to using domestic service providers. However, this practice raises country, compliance, contractual, reputation, operational (e.g., transactional), and strategic issues in addition to those presented by use of a domestic service provider. In managing these issues, management should conduct appropriate risk assessments and due diligence procedures and closely evaluate all contracts. Additionally, management should establish ongoing monitoring and oversight procedures.

RISK MANAGEMENT

A financial institution's senior managers are responsible for understanding the risks associated with foreign-based relationships and for ensuring that effective risk management practices are in place. Management should determine if a foreign-based technology relationship is consistent with the organization's overall business and technology strategies and if it can mitigate identified risks adequately. Before management executes a contract with foreign-based entities, it should consider issues such as choice-of-law and jurisdictional considerations. Additionally, organizations should establish appropriate due diligence and risk management policies that include oversight and monitoring procedures. These policies and procedures should consider that all of the risks associated with domestic third party providers are present in foreign-based arrangements in addition to the unique issues such as country and compliance risks arising from the fact that the third parties may not fall under the jurisdiction of domestic laws and regulations.

COUNTRY RISK

Country risk is an exposure to economic, social, and political conditions in a foreign country that could adversely affect a vendor's ability to meet its service level requirements. In certain situations, country risks could result in the loss of an organization's data, research, or development efforts. Managing country risk requires organizations to gather and assess information regarding foreign political, social, and economic conditions and events, and to address the exposures introduced by the relationship with a foreign-based provider. Risk management procedures should include the establishment of contingency, service continuity, and exit strategies in the event of unexpected disruptions in service.

COMPLIANCE RISK

Compliance risk involves the impact foreign-based arrangements could have on an organization's compliance with applicable U.S. and foreign laws and regulations. An organization's use of a foreign-based third party service provider should not inhibit the organization's compliance with applicable U.S. laws including consumer protection, privacy (Section 501(b) of GLBA) ^[7], and information security laws as well as Bank Secrecy Act requirements ^[8] concerning the reporting and documentation of financial transactions. Additionally, organizations should consider the impact and operational requirements of foreign data privacy laws or regulatory requirements ^[9]. Organizations engaging foreign-based entities should also consider the sanctions and embargo provisions ^[10] of the U.S. Treasury Office of Foreign Assets Control (OFAC) as well as the requirements regarding exportation of encryption-related technologies discussed in the following paragraph.

Export Controls

The United States has export control laws that restrict the export of software and other items (U.S. Export Administration Regulations). ^[11] These laws apply to all aspects of encryption usage, including but not limited to, software, hardware, and network applications. Organizations should ensure they and their service provider(s) comply with these laws. Contracts should include a representation and warranty that service providers will comply with U.S. export control laws.

DUE DILIGENCE

Management of an organization considering a foreign-based outsourcing arrangement should perform appropriate due diligence similar to domestic outsourcing arrangements before selecting or contracting with a service provider. The process should include an evaluation of a firm's financial stability and commitment to service, and the potential impact of the foreign jurisdiction's regulations, laws, accounting standards, and business practices. Additionally, management should consider the degree to which geographic distance, language, or social, economic, or political changes may affect the foreign-based service provider's ability to meet the organization's servicing needs. Management should consider the cost and logistical implications of managing a cross-border relationship, including the ongoing costs of managing and monitoring cross-border and foreign-based provider relationships.

CONTRACTS

Contracts between an organization and a foreign-based entity should address the risks identified during risk assessments and due diligence processes. Specific topics that should be considered regarding such contracts are discussed in the following paragraphs.

Security, Confidentiality and Ownership of Data

Management should require contract provisions to protect its customers' privacy and the confidentiality of organizational records in conformance with U.S. laws and regulations. Federal regulations require that service provider contracts include provisions requiring the service provider to implement procedures and security measures that meet the objectives of customer information security guidelines.^[12] Additionally, contracts should include provisions prohibiting the disclosure of any customer information to nonaffiliated third parties, other than as permitted under U.S. privacy laws.^[13]

Any agreement with a foreign-based service provider should also include a provision that all information transferred to the foreign-based entity remains the property of the organization, regardless of how it is processed, stored, copied, or reproduced.

Regulatory Authority

Arrangements with foreign-based service providers should contain a provision acknowledging the authority of U.S. regulatory authorities^[14] (pursuant to the Bank Service Company Act or the Home Owner's Loan Act) to examine the services performed by the provider.^[15] Financial institutions must not share U.S. regulatory examination reports or information contained therein with either foreign regulators or foreign-based service providers without the express written approval of the appropriate U.S. regulatory authority.

Choice Of Law

Before entering into an agreement or contract with a foreign-based vendor or developer, an organization should carefully consider which country's law it wishes to control the relationship. Based on that review, organizations should include choice of law and jurisdictional covenants that provide for the resolution of disputes between the parties under the laws of a specific jurisdiction.

These provisions are necessary to maintain continuity of service, access to data, and protection of customer information. For these reasons, it can be particularly important when dealing with foreign service providers to specify exactly which country's laws will control the contractual relationship between the parties. Additionally, contract provisions may be subject to foreign-court interpretations of local laws. The laws of the foreign country may not recognize choice of law provisions and may differ from U.S. law regarding what they require of organizations or how they protect bank customers. Thus, an organization's due diligence should include analysis of a country's local laws by legal counsel competent in assessing the enforceability of all aspects of a contract.

MONITORING AND OVERSIGHT

Monitoring foreign entities requires the same steps as monitoring domestic servicers and vendors in addition to the recommendations presented within this appendix. When organizations establish a servicing arrangement with a foreign-based service provider, management should monitor both the entity and the conditions within the foreign country.

The organization should determine that the foreign-based service provider maintains adequate physical and data security controls, transaction procedures, business resumption and IT contingency arrangements (including periodic testing), insurance coverage, and compliance with applicable laws and regulations. Further, where indicated by the organization's security risk assessment, the organization must monitor its foreign-based service providers to confirm that they have satisfied security obligations imposed in the contract to comply with Section 501(b) of GLBA.

Organizations also should monitor economic and governmental conditions within the foreign country to determine whether changes are likely to affect the ability of the service provider to perform under the arrangement.

REGULATORY AGENCY ACCESS TO INFORMATION

U.S. regulatory authorities must have the ability to examine the services performed by an organization's third-party service provider regardless of whether it is foreign or domestically based. Organizations must maintain, in the files of a U.S. office, appropriate English language documentation to support all arrangements with service providers. Appropriate documentation typically includes a copy of the contract establishing the arrangement, supporting legal opinions, due diligence reports, audits, financial statements, performance reports, and other critical information. ^[16] In addition, the organization should have an appropriate contingency plan to ensure continued access to critical information, to maintain service continuity, and the resumption of business functions in the event of unexpected disruptions or restrictions in service resulting from transaction, financial, or country risk developments.

EXAMINATION CONSIDERATIONS

U.S. regulatory authorities may examine the services performed for an organization under an outsourcing arrangement with a foreign-based service provider. Likewise, in the case of a foreign-regulated entity, U.S. regulatory authorities may be able to obtain information through the appropriate supervisory agency in the service provider's home country.

With respect to the outsourcing organization in such arrangements, U.S. regulatory authorities will focus reviews on the adequacy of an organization's due diligence efforts, its risk assessments, and the steps taken to manage those risks including the effect of the arrangement upon the organization's compliance with applicable laws and its access to critical information. Regulatory reviews will assess the organization's contract provisions and its ongoing monitoring or oversight program, including any internal and